GOVERNO DO ESTADO DE MINAS GERAIS
SECRETARIA DE ESTADO DE CULTURA E TURISMO DE MINAS GERAIS (SECULT-MG)
SUPERINTENDÊNCIA DE BIBLIOTECAS, MUSEUS E ECONOMIA DA CRIATIVIDADE (SBMEC)
DIRETORIA DO LIVRO, LEITURA, LITERATURA E BIBLIOTECAS (DLLLB) • SEBPC/MG

DOCUMENTAÇÃO OFICIAL DE ENGENHARIA, DEVOPS E SEGURANÇA • TI SECULT-MG / PRODEMGE

Manual Técnico de Arquitetura, Implantação e Segurança da Informação

Guia de Instalação nos Servidores (Python, Node.js ou PHP 8+), Arquitetura Stateless em 3 Ambientes e Parecer de Segurança para Tomada de Decisão da Equipe de TI da Secult-MG

🔒 SEGURANÇA E CONFORMIDADE LGPD

Arquitetura 100% Read-Only para usuários externos (zero SQLite/SQL, risco zero de SQL Injection). Segregação física de JSON na origem, tokens HMAC-SHA256 em sessionStorage e Rate Limiting nativo por IP.

⚡ ALTA ESCALABILIDADE E ZERO BUILD

Frontends 100% estáticos (HTML5/CSS3/JS puros). Compressão Gzip nativa (-90% de payload), cache condicional ETag/304 (0 KB em recargas) e suporte a cache de borda Nginx.

📑 ÍNDICE TÉCNICO PARA O ANALISTA DE TI

1. **Diretriz Estratégica: Consolidação em Tecnologia Única de Backend**
2. **Arquitetura Desacoplada em 3 Ambientes (Modelo Stateless & Zero Banco de Dados)**
3. **Contrato de Endpoints da API REST e Fluxo de Autenticação Criptográfica**
4. **Procedimento de Instalação nos Servidores — Python 3.8+, Node.js 16+ e PHP 8.0+**
5. **Publicação dos Frontends Estáticos, Reverse Proxy Nginx e Suíte de Auditoria**
6. **Avaliação de Segurança, Matriz de Decisão e Checklist de Homologação da TI**

1. Arquitetura Desacoplada em 3 Ambientes (Stateless & Zero DB)

Arquitetura de Software

> 📌 **DIRETRIZ ESTRATÉGICA PARA A TI (CONSOLIDAÇÃO EM MOTOR ÚNICO DE BACKEND)**
> Para eliminar barreiras de compatibilidade com os servidores da Secult-MG / Prodemge, a camada de API (`00_API_e_Dados`) foi entregue em **3 tecnologias equivalentes e sem dependências externas: Python 3.8+, Node.js 16+ e PHP 8.0+**.
> **Compromisso de Manutenção:** Assim que a equipe de TI homologar e definir qual das três opções será adotada em produção, **as outras duas opções serão formalmente descontinuadas e removidas do repositório**, mantendo apenas a tecnologia escolhida pela TI para simplificar a governança.

O sistema foi projetado sob o princípio de **isolamento físico entre o Portal do Cidadão, o Observatório de Gestão e a Camada de Dados/API**. Após o descarte de módulos transacionais secundários, o sistema opera de forma **100% Stateless sobre arquivos JSON validados**, sem exigir provisionamento, backup ou sustentação de SGBDs relacionais (PostgreSQL, MySQL, Oracle ou SQLite):

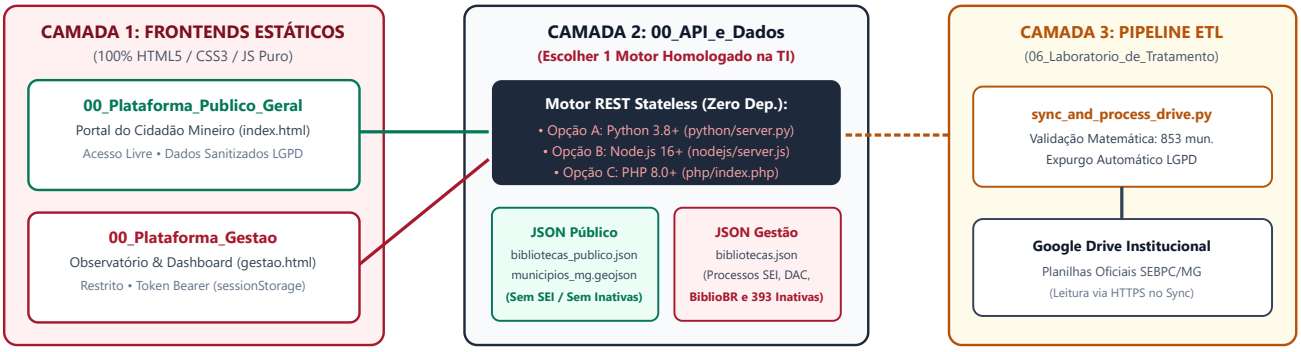


Diagrama 1: Arquitetura física desacoplada em 3 ambientes independentes com segregação na origem (LGPD).

1.1 Estrutura de Diretórios e Contrato de Endpoints da API

Endpoint REST	Autenticação	Política de Cache / Segurança	Comportamento Técnico
`GET /api/status`	Público	`Cache-Control: no-store`	Retorna status operacional, motor ativo (Python/Node/PHP) e versão.
`GET /api/publico/bibliotecas`	Público	`public, max-age=300` + `ETag` + `gzip`	Serve `bibliotecas_publico.json` (~90,6 KB via Gzip; 0 KB em `304`). Expurgado de dados internos (LGPD).
`GET /api/publico/municipios`	Público	`public, max-age=300` + `ETag` + `gzip`	Serve a malha `municipios_mg.geojson` (853 municípios IBGE).
`GET /api/publico/regioes`	Público	`public, max-age=300` + `ETag` + `gzip`	Serve a malha `regioes_mg.geojson` (13 Regiões Intermediárias).
`POST /api/auth/login`	Público	**Rate Limiting:** máx. 5 falhas / 15 min por IP (`HTTP 429`)	Valida a senha institucional e emite token `HMAC-SHA256` com validade de 12 horas.
`GET /api/gestao/bibliotecas`	Bearer Token	`private, no-cache` + `ETag` + `gzip`	Exige cabeçalho `Authorization: Bearer <token>`. Serve `bibliotecas.json` completo (SEI, DAC, Inativas).
`POST /api/sync-drive`	Bearer Token	Mutex Lock + Cooldown de 60s	Aciona `sync_and_process_drive.py` para atualizar os JSONs a partir do Google Drive oficial.

2. Guia de Instalação nos Servidores (Para Cada Tecnologia)

Implantação & DevOps

2.1 Variáveis de Ambiente de Segurança Obrigatórias (Comuns aos 3 Motores)

Independentemente do motor de backend escolhido pela TI (Python, Node.js ou PHP), o servidor de produção **deve** ter as seguintes variáveis de ambiente configuradas:

Variável de Ambiente	Criticidade	Descrição e Comando Sugerido para Geração
`SEBPC_AUTH_SECRET`	Obrigatória	Chave secreta criptográfica para assinatura `HMAC-SHA256` dos tokens Bearer. Gerar com: `openssl rand -hex 32` (64 caracteres hexadecimais).
`SEBPC_ADMIN_PASSWORD`	Obrigatória	Senha institucional forte para login na Área de Gestão (substitui automaticamente a senha padrão de homologação).
`SEBPC_ALLOWED_ORIGIN`	Recomendada	Domínio autorizado no cabeçalho CORS (ex.: `https://minascriativa.cultura.mg.gov.br`).
`PORT_API` / `HOST_API`	Opcional	Porta e endereço de escuta local (padrão: `PORT_API=8090` e `HOST_API=127.0.0.1`).

2.2 Opção A — Instalação com Backend Python 3.8+ (`00_API_e_Dados/python/server.py`)

Requisitos: Python 3.8 ou superior. A API utiliza **100% Biblioteca Padrão do Python** (zero pacotes externos para servir requisições HTTP). Apenas para o script de sincronização de planilhas Excel do Google Drive é necessário o pacote `openpyxl` (`pip3 install openpyxl`).

```
# Arquivo: /etc/systemd/system/sebpc-api.service
[Unit]
Description=API REST Stateless - Sistema Estadual de Bibliotecas (SEBPC/MG)
After=network.target

[Service]
Type=simple
User=www-data
Group=www-data
WorkingDirectory=/var/www/sistema_bibliotecas
Environment="HOST_API=127.0.0.1"
Environment="PORT_API=8090"
Environment="SEBPC_AUTH_SECRET=COLE_AQUI_64_HEX_GERADOS_POR_OPENSSL_RAND"
Environment="SEBPC_ADMIN_PASSWORD=DEFINA_A_SENHA_INSTITUCIONAL_FORTE"
Environment="SEBPC_ALLOWED_ORIGIN=https://minascriativa.cultura.mg.gov.br"
ExecStart=/usr/bin/python3 /var/www/sistema_bibliotecas/00_API_e_Dados/python/server.py
Restart=always
RestartSec=3

[Install]
WantedBy=multi-user.target
```

Comandos para ativação do serviço no Linux:

```
sudo systemctl daemon-reload && sudo systemctl enable --now sebpc-api.service
```

2.3 Opção B — Instalação com Backend Node.js 16+ (`00_API_e_Dados/nodejs/server.js`)

Requisitos: Node.js 16+ (LTS 18/20/22). **Zero** `node_modules` — utiliza exclusivamente módulos nativos (`node:http` , `node:fs` , `node:crypto` , `node:zlib`). Não requer `npm install` , eliminando riscos de cadeia de suprimentos (*Supply Chain Attacks*).

```
# Para rodar via systemd, basta alterar o ExecStart da unidade acima para:
ExecStart=/usr/bin/node /var/www/sistema_bibliotecas/00_API_e_Dados/nodejs/server.js

# Ou, caso a TI utilize o gerenciador PM2:
SEBPC_AUTH_SECRET="$(openssl rand -hex 32)" SEBPC_ADMIN_PASSWORD="DEFINA_A_SENHA_INSTITUCIONAL_FORTE"
SEBPC_ALLOWED_ORIGIN="https://minascriativa.cultura.mg.gov.br" PORT_API=8090 pm2 start
/var/www/sistema_bibliotecas/00_API_e_Dados/nodejs/server.js --name "sebpc-api"
pm2 save
```

2.4 Opção C — Instalação com Backend PHP 8.0+ (`00_API_e_Dados/php/index.php`)

Requisitos: Servidor Web Apache 2.4 (com `mod_rewrite`) ou Nginx + `PHP-FPM 8.0+`. Não requer nenhum banco de dados (nem MySQL, nem PostgreSQL, nem SQLite). A pasta `00_API_e_Dados/php/` já possui `.htaccess` configurado.

```
# Exemplo 1: Apache 2.4 VirtualHost
<VirtualHost *:443>
    ServerName api.minascriativa.cultura.mg.gov.br
    DocumentRoot /var/www/sistema_bibliotecas/00_API_e_Dados/php

    SetEnv SEBPC_AUTH_SECRET "COLE_AQUI_64_HEX_GERADOS_POR_OPENSSL_RAND"
    SetEnv SEBPC_ADMIN_PASSWORD "DEFINA_A_SENHA_INSTITUCIONAL_FORTE"
    SetEnv SEBPC_ALLOWED_ORIGIN "https://minascriativa.cultura.mg.gov.br"

    <Directory /var/www/sistema_bibliotecas/00_API_e_Dados/php>
        Options -Indexes +FollowSymLinks
        AllowOverride All
        Require all granted
    </Directory>
</VirtualHost>
```

```
# Exemplo 2: Bloco Nginx + PHP-FPM
location /api/ {
    root /var/www/sistema_bibliotecas/00_API_e_Dados/php;
    try_files $uri /index.php?$query_string;
    include fastcgi_params;
    fastcgi_pass unix:/run/php/php8.2-fpm.sock;
    fastcgi_param SCRIPT_FILENAME /var/www/sistema_bibliotecas/00_API_e_Dados/php/index.php;
    fastcgi_param SEBPC_AUTH_SECRET "COLE_AQUI_64_HEX_GERADOS_POR_OPENSSL_RAND";
    fastcgi_param SEBPC_ADMIN_PASSWORD "DEFINA_A_SENHA_INSTITUCIONAL_FORTE";
    fastcgi_param SEBPC_ALLOWED_ORIGIN "https://minascriativa.cultura.mg.gov.br";
}
```

2.5 Publicação dos 2 Frontends Estáticos e Reverse Proxy Nginx

Os diretórios `00_Plataforma_Publico_Geral/` e `00_Plataforma_Gestao/` contêm apenas HTML, CSS e JS puros. Antes de publicá-los, ajuste a constante `DEFAULT_API_URL` na linha inicial de `js/api_config.js` em ambas as pastas para apontar para o domínio HTTPS de produção.

```
# Configuração Recomendada Nginx (Frontends Estáticos + Proxy API com Cache de Borda)
proxy_cache_path /var/cache/nginx/sebpc_public levels=1:2 keys_zone=sebpc_cache:10m max_size=100m
inactive=10m use_temp_path=off;

server {
    listen 443 ssl http2;
    server_name minascriativa.cultura.mg.gov.br;

    # Cabeçalhos de Segurança HTTP (Hardening Secult-MG)
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;

    # Ambiente 1: Portal Público Geral (/)
    location / {
        root /var/www/sistema_bibliotecas/00_Plataforma_Publico_Geral;
        index index.html;
        try_files $uri $uri/ /index.html;
    }

    # Ambiente 2: Observatório de Gestão (/gestao/)
    location /gestao/ {
        alias /var/www/sistema_bibliotecas/00_Plataforma_Gestao/;
        index gestao.html;
        try_files $uri $uri/ /gestao/gestao.html;
    }

    # Ambiente 3: Endpoints Públicos da API (Cache de 5 min no Nginx)
    location /api/publico/ {
        proxy_pass http://127.0.0.1:8090;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_cache sebpc_cache;
        proxy_cache_valid 200 5m;
    }

    # Endpoints de Autenticação e Gestão (Sem Cache Público)
    location /api/ {
        proxy_pass http://127.0.0.1:8090;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
    }
}
```

3. Avaliação de Segurança e Apoio à Decisão (Ótica da TI Secult-MG)

Auditoria de Segurança & Governança

Esta seção apresenta a avaliação técnica independente do sistema sob a ótica de **Segurança da Informação, Escalabilidade e Sustentação da TI da Secult-MG / Prodemge**, estruturada para apoiar as decisões de homologação do analista responsável.

3.1 Matriz de Apoio à Decisão: Qual Tecnologia de Backend Escolher?

Como definido na diretriz do projeto, **após a escolha da TI, as outras duas opções de backend serão descartadas** para que a manutenção concentre-se em um único código. Abaixo estão os critérios objetivos para a escolha:

Critério da TI	Opção A: Python 3 (`server.py`)	Opção B: Node.js (`server.js`)	Opção C: PHP 8+ (`index.php`)
Unificação Tecnológica com o Sincronizador Google Drive	**Vantagem Máxima** O pipeline ETL (`sync_and_process_drive.py`) já é escrito em Python. Permite manter apenas 1 linguagem no servidor.	Exige que o `python3` também esteja instalado no servidor caso a equipe utilize o botão `Sincronizar` na interface web.	Exige `python3` instalado no servidor e permissão para `exec()` / `shell_exec()` caso usem o botão `Sincronizar`.
Dependências e Risco de Vulnerabilidades (CVE)	**Zero pacotes externos** na API (100% stdlib).	**Zero pacotes externos** (sem `node_modules`).	**Zero pacotes externos** (sem Composer/bibliotecas de terceiros).
Sustentação Operacional	Serviço `systemd` leve (~22 MB RAM) com cache de Gzip/ETag em memória.	Serviço `systemd` / `PM2` (~40 MB RAM) com I/O assíncrono de alta vazão.	Não requer processo daemon; roda direto no Apache ou PHP-FPM padrão.
Parecer Recomendado ao Analista de TI	🏆 **Recomendado Principal** para VMs Linux ou Containers, por unificar API e ETL em Python puro.	**Recomendado** se o parque da Secult padronizar microsserviços em Node.js.	**Recomendado** para ambientes de hospedagem compartilhada Apache/PHP tradicional.

3.2 Diagnóstico dos Controles de Segurança Já Implementados no Sistema

Domínio de Segurança	Avaliação	Implementação Técnica Auditada no Código
1. Isolamento de Dados e LGPD (Lei 13.709/2018)	**Excelente (9,8/10)**	Segregação física na origem: o arquivo público (`bibliotecas_publico.json`) não contém números de Processos SEI, IDs BiblioBR, notas administrativas, histórico de assessorias nem dados dos 393 municípios inativos.
2. Superfície de Escrita e Injeção (SQLi / XSS)	**Excelente (9,8/10)**	**Risco Zero de SQL Injection:** Não há banco de dados SQL/SQLite nem endpoints públicos de gravação. A API opera em modo 100% *Read-Only* sobre arquivos JSON estáticos pré-processados.
3. Autenticação e Gestão de Sessão	**Alta (9,4/10)**	Autenticação server-side com tokens assinados `HMAC-SHA256` (validade de 12h), verificação em tempo constante (*Timing-Safe*) e armazenamento restrito ao `sessionStorage` (enviado apenas via header `Authorization: Bearer`).
4. Proteção contra Força Bruta e Abuso (DoS)	**Alta (9,5/10)**	*Rate Limiting* nativo por IP no endpoint `POST /api/auth/login` (bloqueio `HTTP 429` por 15 minutos após 5 falhas) e trava *mutex* com *cooldown* de 60s no endpoint autenticado `POST /api/sync-drive`.
5. Segurança na Exportação de Planilhas	**Alta (9,6/10)**	Sanitização contra *CSV/Excel Formula Injection* em ambos os frontends (neutralização automática de células iniciadas por `=`, `+`, `-` ou `@`).

3.3 Ações de Hardening Requeridas da TI no Momento do Deploy

> ⚠️ **3 Parametrizações Obrigatórias no Deploy de Produção (Checklist de Segurança da TI)**
>
> 1. **[SEC-01] Definir `SEBPC_AUTH_SECRET` e `SEBPC_ADMIN_PASSWORD` no Servidor:** O código possui valores fallback para homologação local. Em produção, a TI deve obrigatoriamente injetar uma chave aleatória de 256 bits e uma senha forte via variáveis de ambiente.
> 2. **[SEC-02] Definir `SEBPC_ALLOWED_ORIGIN`:** Parametrizar o domínio oficial (ex.: `https://minascriativa.cultura.mg.gov.br`) para bloquear requisições CORS de origens externas não autorizadas.
> 3. **[SEC-03] Restringir a Chave Pública do Google Maps por Referenciador HTTP:** No Console do Google Cloud, restringir o uso da chave `AIza...` exclusivamente aos domínios `*.cultura.mg.gov.br/*` para proteger a franquia institucional da Secult-MG.

3.4 Validação Pós-Implantação Automatizada (17 Testes de Auditoria)

O sistema acompanha uma suíte de auditoria automatizada (sem dependências externas) que verifica fechamento matemático dos 853 municípios, expurgo LGPD, autenticação `401/200`, compressão Gzip e cache ETag `304`:

```
node 06_Laboratorio_de_Tratamento_Tecnico/test_suite_completa.js
```